Отчёт о киберинциденте для руководства

РЕЗЮМЕ

Период инцидента: 30 апреля 2025 - 3 мая 2025
Дата обнаружения: 2 мая 2025, утро
Уровень критичности: Высокий (Critical)
Затронутые системы: Веб-сервер (10.0.0.22), файловый сервер (10.0.0.15), контроллер домена Active Directory (10.0.0.10)
Текущий статус: Расследование завершено

30 апреля 2025 года внешний злоумышленник получил несанкционированный доступ к веб-серверу компании Demo Lab через уязвимость веб-приложения. В течение двух суток атака распространилась на внутреннюю инфраструктуру: файловый сервер, контроллер домена и рабочую станцию. Злоумышленник похитил учётные данные администраторов, получил полный контроль над доменом Active Directory и вывел за пределы компании конфиденциальные данные (архивы общим объёмом не менее 25 МБ). Инцидент классифицирован как критический - скомпрометирован ключевой узел инфраструктуры (контроллер домена) и подтверждена утечка данных.

ДЕТАЛИ ИНЦИДЕНТА

Обнаружение и первичная оценка

Инцидент выявлен утром 2 мая 2025 года сотрудником службы информационной безопасности, который заметил подозрительный сетевой трафик от внутреннего веб-сервера к неизвестному внешнему IP-адресу. Предварительная проверка показала следы компрометации и признаки утечки данных. Служба ИБ инициировала расследование.

Краткое описание событий

1. 30 апреля, 07:07. Злоумышленник нашёл уязвимость в веб-приложении Nginx на эндпоинте /nginx_status, загрузил вредоносный скрипт и получил удалённый доступ к веб-серверу.
2. 30 апреля, 08:53. Атакующий закрепился в системе через crontab, поднял привилегии до root и вытащил хеши паролей Linux-пользователей из /etc/shadow.
3. 30 апреля, 15:42. С украденными учётными данными зашёл на файловый сервер.
4. 30 апреля, 18:08. Через mimikatz вытащил из памяти файлового сервера учётные данные доменного администратора.
5. 30 апреля, 19:23. Началась утечка: с файлового сервера ушёл первый архив с документами.
6. 1 мая, 01:45. По RDP зашёл на контроллер домена под украденной учёткой администратора.
7. 1 мая, 04:17. Провёл DCSync-атаку и забрал главный секрет домена (krbtgt). Это даёт возможность подделывать любые учётные записи в AD.

8. 1 мая, 18:59. Очистил журнал безопасности контроллера домена, чтобы замести следы.
9. 2 мая, 19:36. Финальная фаза: выкачал данные с контроллера домена.

Масштаб воздействия

1. **Затронутые системы:**
   - Веб-сервер (10.0.0.22) - скомпрометирован полностью
   - Файловый сервер (10.0.0.15) - скомпрометирован полностью
   - Контроллер домена (10.0.0.10) - скомпрометирован полностью
   - Рабочая станция (10.0.0.30) - есть признаки активности атакующего, но следов локального входа нет
2. **Похищенные данные:**
   - Минимум три архива с документами, общий объём не менее 25 МБ (один архив примерно 26,8 МБ, ещё два - около 7,7 и 2,1 МБ)
   - Хеши паролей Linux-пользователей
   - Учётные данные доменного администратора
   - Главный секрет домена krbtgt (позволяет выдавать себя за любого пользователя AD)
3. **Последствия для бизнеса:**
   - Контроль над доменом Active Directory полностью потерян на момент обнаружения. Атакующий мог создавать учётки, менять права, заходить на любые ресурсы.
   - Утечка внутренних документов - репутационные и регуляторные риски, возможны претензии клиентов и партнёров.
   - Придётся восстанавливать контроллер домена из резервной копии, что означает простой.
   - Нужна массовая смена паролей всех привилегированных пользователей.

ПРЕДПРИНЯТЫЕ МЕРЫ

ПРЕДПРИНЯТЫЕ МЕРЫ

Немедленные действия:

- Провели полное расследование: определили все скомпрометированные системы, каналы атаки и признаки взлома.
- Собрали индикаторы компрометации: IP-адреса, домены, хеши файлов, пути.
- Подготовили правила обнаружения: 5 правил корреляции в ELK, 2 правила Snort, правила Auditd и Sysmon.
- Заблокировали IP-адреса и домены атакующего на межсетевом экране.
- Составили план восстановления контроллера домена из чистой резервной копии.
- Определили список учётных записей для обязательной смены паролей (в первую очередь krbtgt, administrator, webadmin).

Восстановление:

- Изолировали скомпрометированные системы от сети.
- Сменили пароль krbtgt дважды с интервалом (иначе атакующий сохранит возможность выпускать Golden Ticket).
- Начали массовую смену паролей всех привилегированных учёток.
- Удалили вредоносные артефакты: webshell.php, kernel_exploit.ko, mimikatz.exe, smbScanner.exe, изменённый crontab.
- Восстанавливаем контроллер домена из резервной копии, сделанной до 30.04.2025.
- Запустили внеплановое сканирование всех хостов на остатки индикаторов.

ТЕКУЩИЙ СТАТУС

- Оценка ущерба: утечка подтверждена, объём - не менее 25 МБ. Финансовую и репутационную оценку ещё считаем.
- Расследование: завершено. Все этапы атаки восстановлены, источник найден, каналы утечки подтверждены.
- Восстановление: в процессе. В приоритете - смена krbtgt, восстановление контроллера домена из бэкапа, массовая смена паролей.
- Статус инцидента: локализован. Активность атакующего остановлена, занимаемся последствиями.

РЕКОМЕНДАЦИИ

Краткосрочные меры (1–2 недели)

1. **Смена учётных данных:**
   - Сменить пароль krbtgt дважды с интервалом.
   - Сменить пароли всех административных учёток домена.
   - Сменить пароли локальных администраторов на всех серверах.
   - Отозвать и перевыпустить все SSH-ключи на Linux-хостах.
2. **Проверка систем:**
   - Внепланово просканировать все хосты на индикаторы компрометации.
   - Восстановить контроллер домена из чистой резервной копии.
   - Удалить вредоносные артефакты со скомпрометированных машин.
3. **Коммуникация:**
   - Уведомить руководство и ключевых стейкхолдеров.
   - Подготовить уведомление для клиентов и партнёров, если потребуется.
   - Проверить регуляторные требования и сроки уведомления.

Среднесрочные меры (1–3 месяца)

1. **Защита периметра:**
   - Провести аудит веб-приложений на уязвимости.
   - Настроить WAF для защиты Nginx.
   - Внедрить регулярное сканирование уязвимостей.

2. **Внутренняя безопасность:**
   - Сегментировать сеть: вынести веб-серверы в DMZ, запретить прямой SMB/RDP-доступ к внутренним системам.
   - Включить защиту LSASS (Credential Guard, RunAsPPL) на всех Windows-хостах.
   - Запретить использование внешних DNS-резолверов (8.8.8.8 и подобных).
   - Расширить мониторинг: полный Sysmon на Windows, Auditd на Linux, сбор логов с рабочих станций.
3. **Процессы:**
   - Разработать регламент эскалации при подозрительной активности.
   - Сделать обязательной корреляцию источников (DLP + Sysmon + PCAP) при подозрении на утечку.
   - Проводить учения по реагированию на инциденты раз в квартал.

Долгосрочные меры (3–12 месяцев)

1. **Стратегические изменения:**
   - Внедрить концепцию Zero Trust.
   - Пересмотреть архитектуру сетевой безопасности.
   - Проводить регулярные аудиты прав доступа и привилегированных учёток.
2. **Инвестиции в технологии:**
   - Внедрить EDR на все хосты.
   - Внедрить SIEM с расширенной корреляцией и UEBA.
   - Обновить DLP для блокировки утечек через TLS и SMTP.
   - Вложиться в защиту от фишинга и обучение сотрудников.

ИЗВЛЕЧЁННЫЕ УРОКИ

1. **Уязвимость в веб-приложении - главный вектор атаки.** Инъекция команд в Nginx стала стартовой точкой для всей цепочки. Нужен регулярный аудит веб-приложений и WAF.
2. **Избыточные привилегии усугубляют последствия.** Учётка webadmin имела админ-права на файловом сервере, хотя не должна была. Это дало атакующему прямой путь от веб-сервера к критичному узлу. Принцип наименьших привилегий нужно соблюдать строго.
3. **Защита контроллера домена - приоритет.** Компрометация krbtgt даёт атакующему контроль над доменом на годы. Нужен мониторинг DCSync-активности, ограничение прав на репликацию AD, своевременный алертинг на события 4662 и 1102.
4. **Мониторинг должен быть всеобъемлющим.** Из-за отсутствия логов с рабочих станций и пробелов в конфигурации Sysmon расследование шло тяжелее. Аудит конфигураций мониторинга нужно проводить регулярно.

ВЫВОД

Инцидент в Demo Lab - критический. Злоумышленник получил полный контроль над доменом Active Directory и выкачал конфиденциальные данные. Атака шла больше двух

суток, часть этапов (DCSync, очистка журналов) удалось поймать только благодаря централизованному SIEM и независимым источникам логов.

Служба ИБ сработала оперативно, картину инцидента восстановили полностью. Но сам факт успешной компрометации ключевого узла говорит о том, что систему защиты нужно серьёзно пересматривать.

Приоритеты: смена всех скомпрометированных учётных данных (в первую очередь krbtgt), восстановление контроллера домена из чистой резервной копии, сегментация сети, защита LSASS и расширение мониторинга. Если всё это сделать, риск повтора снизится в разы.

Отчёт подготовил: [Егоров Николай, SOC-аналитик]
Дата: [03.10.2026]